CRA (Cyber Resilience Act) 概要と最新動向

October 22, 2026

OpenChain Japan Community Day vol.36
(OpenChain Japan & OpenSSF Collaboration Event)

OpenSSF Japan Working Group

余保 東（ルネサスエレクトロニクス）



Copyright © 2026 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.
This slide is licensed under the Creative Commons Zero 1.0 Universal

自己紹介



ルネサスエレクトロニクス株式会社
余保 束

LinkedIn

- 経歴
  - ✔ 4/8bitマイコン向け組込みSWエンジニア（アセンブリ言語）
  - ✔ 16bitマイコン向け組込みSWエンジニア（C言語）
  - ✔ 組込みセキュリティエンジニア
  - ✔ PSIRT(Product Security Incident Response Team)
  - ✔ 社内OSS活動推進
- Linux Foundation community
  - ✔ OpenSSF Japan Working Group
  - ✔ OpenChain Japan WG

セキュリティの難しさ

システム全体の堅牢性はシステムの中で最も脆弱な箇所で決まる（桶理論）

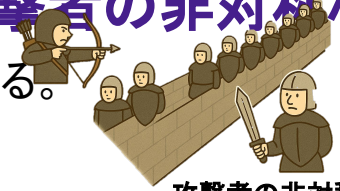
-ライフサイクル全てに渡ってセキュリティを考える必要があ



桶の水は一番低い
所から漏れる

攻撃者はセキュリティホールを 1か所見つければ良く、守る側はセキュリティホールが 1か所もあってはならない（攻撃者の非対称な優位性）

-サプライチェーン全体でセキュリティを考える必要がある。



たった1か所が脆弱だと
攻め込まれてしまう

攻撃者の非対称な優位
性

これが揃ってセキュリティが確保される　→　CRAでは両方が求められる

OpenChain and OpenSSF

OpenChainとOpenSSFが連名で10月初旬に文書を発行



- 規制（CRAやNIS2）とそれに伴う顧客要求が強まる中で、組織的なガバナンスとセキュア開発の両面から、ソフトウェアサプライチェーンの信頼性を向上させる考え方をガイド
- OpenChain と OpenSSF がソフトウェアサプライチェーンセキュリティに対してどのように補完関係にあるかを説明し両者を組み合わせた実践方法を解説



openssf_openchai
pplychainsecurity_

Strengthening Software Supply Chain Security with OpenChain and OpenSSF – Open Source Security Foundation

Disclaimer

スピーカーは法律の専門家ではありません。

ここではスピーカーが CRA（EU Cyber Resilience Act）をウォッチし調べたことを共有しますが、誤りを含む可能性があります。

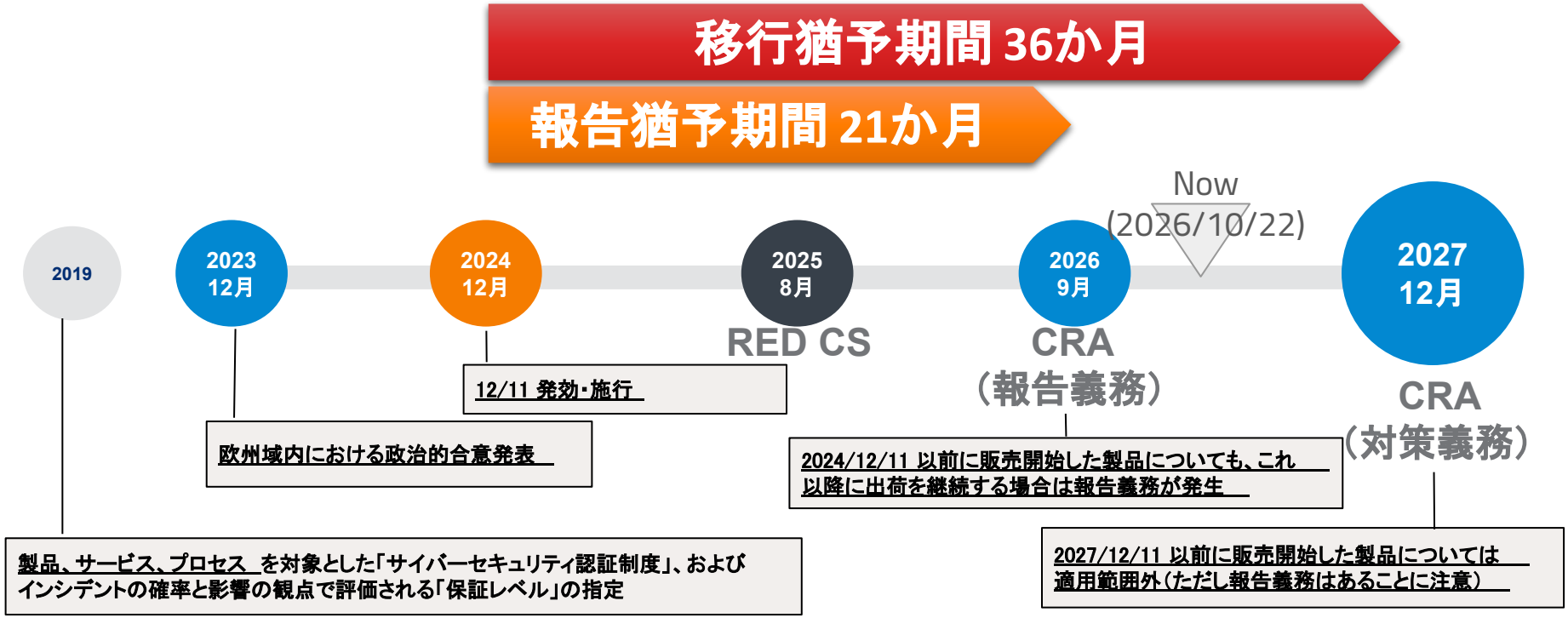
法令の正確・正式な意味・解釈は、別途専門家に確認を取ることをお勧めいたします。

Agenda

- CRA タイムライン
- 対象になる機器と分類
- CRA適用対象（出荷時期）
- 用語・登場人物の整理
- CRAの要点
- 罰則・制約
- 最新動向
- LF Trainingの紹介

CRAタイムライン

EU CRA タイムライン

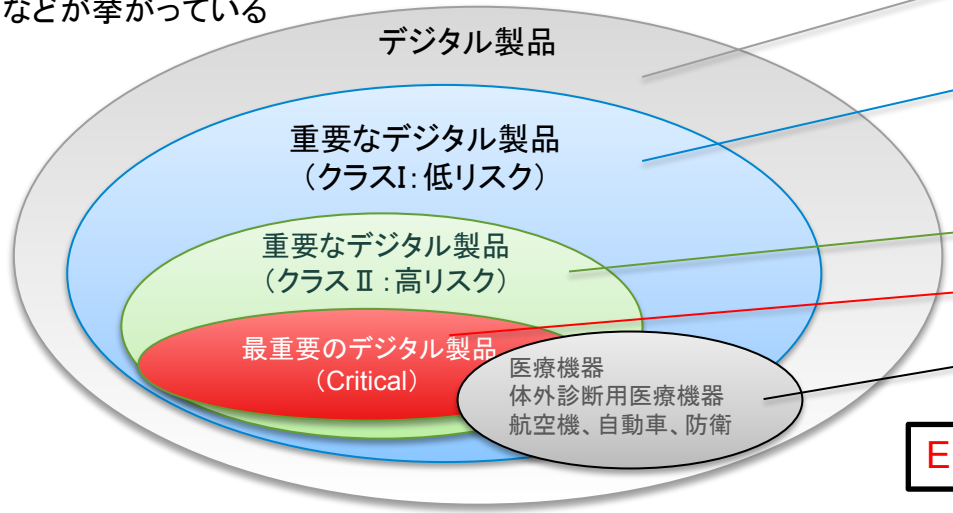


対象になる機器と分類

CRA の対象機器範囲と求められる対応

出典：Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (Text with EEA relevance)
< https://eur-lex.europa.eu/eli/reg/2024/2847/ >

- 外部とデータのやり取りを行うデジタル製品全てが対象
  →何らかの半導体プロセッサと制御プログラムを有するほとんどの製品および機能の一部を実現する外部ソリューションが対象となる
- 第三者認証免除・軽減のための整合規格は 検討中
  → 予想では「IEC62443」「EUCC」「ETSI EN 303 645」などが挙がっている



- 「セキュリティ特性要件」を満たす
- 更新プログラム提供を含む「脆弱性処理要件」の遵守

→□□**適合宣**□か**第三者認証** 取得

別途定める整合規格への適合、
または**第三者認証** 取得
- 整合規格は未定（EUCC、EN規格が有力？）

第三者認証 取得

第三者認証 取得

適用範囲外（業界規則への適合）

EU適合宣言（CEマーク）取得要件に組込まれる

「重要な」デジタル製品の具体例

クラスⅠ（低リスク）*Annex III

「重要な」デジタル製品であるが、リスクが低い製品

1. 認証およびアクセス制御リーダー（生体認証リーダーを含む）を含む、アイデンティティ管理システムおよび特権アクセス管理ソフトウェアとハードウェア
2. スタンドアロンおよび組み込みブラウザ
3. パスワード マネージャー
4. 悪意のあるソフトウェアを検索、削除、または隔離するソフトウェア
5. 仮想プライベート ネットワーク (VPN) 機能を備えたデジタル要素を備えた製品
6. ネットワーク管理システム
7. セキュリティ情報およびイベント管理 (SIEM) システム
8. ブート マネージャー
9. 公開鍵インフラストラクチャおよびデジタル証明書発行ソフトウェア
10. 物理および仮想ネットワーク インターフェイス
11. オペレーティング システム
12. インターネットへの接続を目的としたルーター、モデム、およびスイッチ
13. セキュリティ関連機能を備えたマイクロプロセッサ
14. セキュリティ関連機能を備えたマイクロコントローラ
15. セキュリティ関連機能を備えた特定用途向け集積回路（ ASIC）およびフィールドプログラマブルゲートアレイ（FPGA）
16. スマートホーム汎用仮想アシスタント
17. スマートドアロック、セキュリティカメラ、ベビーモニタリングシステム、アラームシステムなどのセキュリティ機能を備えたスマートホーム製品
18. 欧州議会および理事会指令 2009/48/EC（45）の対象となるインターネット接続玩具で、ソーシャルインタラクティブ機能（会話や撮影など）または位置追跡機能を備えているもの
19. 健康モニタリング（追跡など）目的があり、規則（ EU）2017/745または規則（EU）2017/746が適用されない、人体に装着または装着される個人用ウェアラブル製品、または子供が使用することを目的とした個人用ウェアラブル製品。

クラスⅡ（高リスク）*Annex III

「重要な」デジタル製品のうち、リスクが□い製品

1. オペレーティングシステムおよび同様の環境の仮想実行をサポートするハイパーバイザーおよびコンテナランタイムシステム
2. ファイアウォール、侵入検知および防止システム
3. 改ざん防止マイクロプロセッサ
4. 改ざん防止マイクロコントローラ

「（最：Critical ）重要な」デジタル製品

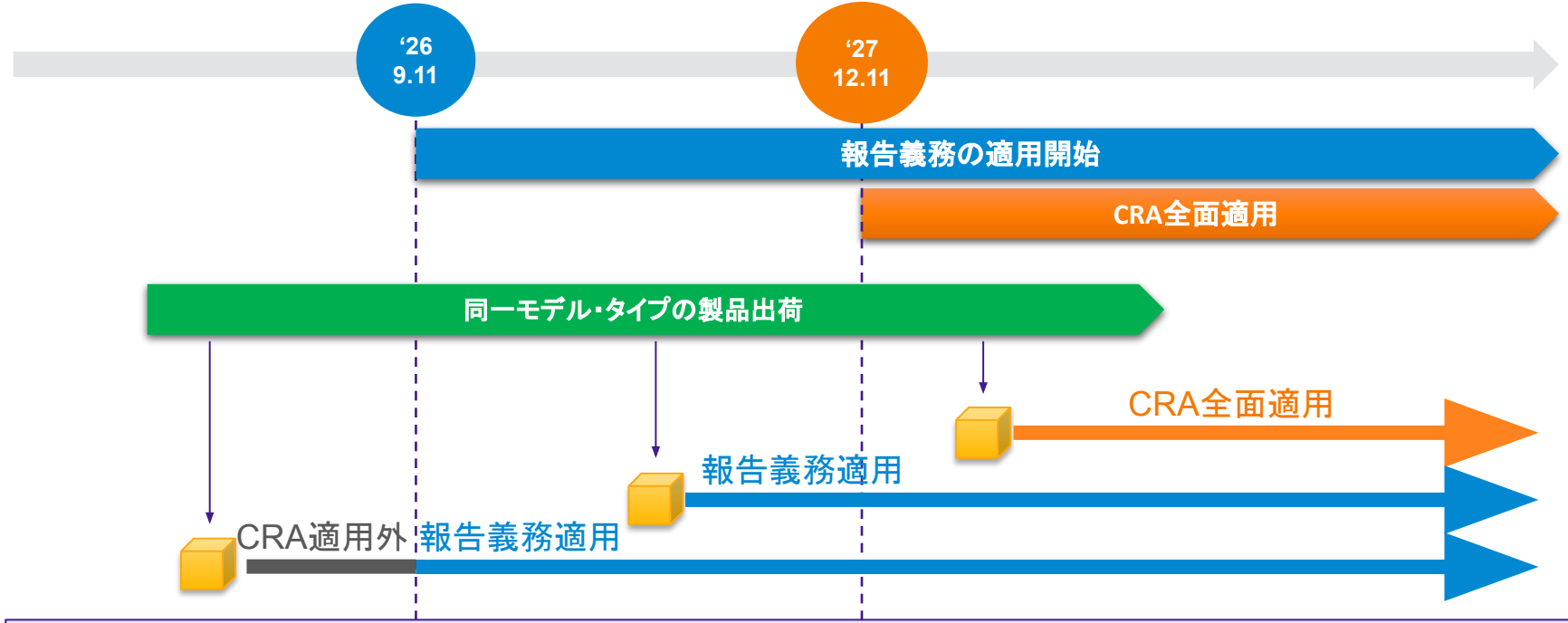
* Annex IV

1. セキュリティボックスを備えたハードウェアデバイス
2. 欧州議会および理事会の指令(EU) 2019/944(46) の第 2 条 (23) で定義されているスマートメーター システム内のスマートメーター ゲートウェイ、および安全な暗号処理を含む高度なセキュリティを目的としたその他のデバイス
3. セキュア エレメントを含むスマートカードまたは類似のデバイス

出典：European Parliament legislative resolution of 12 March 2024 on the proposal for a regulation of the European Parliament and of the Council on horizontal cybersecurity requirements for products with digital elements and amending Regulation (EU)
<https://data.consilium.europa.eu/doc/document/PE-100-2023-REV-1/EN/pdf>

CRA適用対象（出荷時期）

適用対象の出荷時期



上市は個々の製品単位。同一モデル･タイプの製品が CRA全面適用前に上市されていても、CRA全面適用後に出荷した製品は上市と扱われ、CRA全面適用対象

用語・登場人物の整理

用語・登場人物の整理

用語 (第3条)

- **デジタル要素を含む製品 (PDE or PwDE: product with digital elements)**
  ソフトウェアまたはハードウェア製品とその遠隔データ処理ソリューションを意味し、ソフトウェアまたはハードウェアのコンポーネントが個別に市場に出回る場合も含む
- **マニュファクチャラー (manufacturer)**
  デジタル要素を有する製品を開発もしくは製造する、またはデジタル要素を有する製品を設計、開発もしくは製造させ、有償、収益化、無償を問わず、その名称または商標の下で販売する自然人または法人
- **輸入業者**(importer)
  EU域外に設立された自然人または法人の名称または商標が付されたデジタル要素を有する製品を市場に出す、EU域内に設立された自然人または法人
- **販売業者**(distributor)
  サプライチェーンの中で、マニュファクチャラーまたは輸入業者以外の自然人または法人で、デジタル要素を含む製品を、その特性に影響を与えることなく連合市場で入手できるようにする者

用語・登場人物の整理

用語（続き）

- **フリー・オープンソースソフトウェア** (free and open-source software)
  ソースコードがオープンに共有され自由にアクセスし、使用し、改変し、再配布できるようにするすべての権利を提供するフリー・オープンソースライセンスの下で利用可能にされたソフトウェア
- **オープンソース・ソフトウェア・スチュワード (open-source software steward)**
  マニュファクチャラー以外の法人でフリーかつオープンソースソフトウェアとして適格であり、商業活動を目的としたデジタル要素を含む特定の製品の開発に対して、体系的な支援を継続的に提供する目的または目標を持ち、それらの製品の実行可能性を保証するもの

用語・登場人物の整理

用語（続き）

- **サポート期間(support period)**
  デジタル要素を含む製品の脆弱性が、附属書 Ⅰの第 Ⅱ 部に規定される本質的なサイバーセキュリティ要件に従って効果的に処理されることを確保するために製造者が必要とする期間
- **上市(placing on the market)**
  デジタル要素を含む製品を連合市場で最初に入手可能にすること
- **CEマーキング**(CE marking)
  製造者が、デジタル要素を有する製品およびその製造者が実施するプロセスが、附属書Ⅰに定めるサイバーセキュリティの必須要件およびその貼付を規定する他の適用可能な EU調和法令に適合していることを示すマーキング

用語・登場人物の整理

用語（続き）

- **ソフトウェア部品表 (software bill of materials)**
  デジタル要素を有する製品のソフトウェア要素に含まれるコンポーネントの詳細およびサプライチェーン関係を含む正式な記録
- **脆弱性**(vulnerability)
  サイバー脅威によって悪用される可能性のある、デジタル要素を持つ製品の弱点、感受性、欠陥
- **実際に悪用された脆弱性 (actively exploited vulnerability)**
  悪意のある行為者がシステム所有者の許可なくシステムでその脆弱性を悪用したという信頼できる証拠がある脆弱性

CRA の要点

CRAの要点

CRAの原則：PDEの製造業者（マニュファクチャラー）に対する要求

＜マニュファクチャラーに求められる要件＞

1. セキュリティ・バイ・デザイン
2. 脆弱性管理
3. セキュリティアップデートの提供
4. 報告義務

1. セキュリティ・バイ・デザイン

- サイバーセキュリティ上のリスクアセスメントを実施し、その結果を設計・開発・製造・配送・メンテナンスの際の考慮に□れる必要がある(Article13(2))
- サイバーセキュリティリスクアセスメントは、文書化され、適宜更新されること(Article13(3))
- 詳細は附属書 Ⅰ パートⅠ「セキュリティ要件」に記載

2. 脆弱性管理

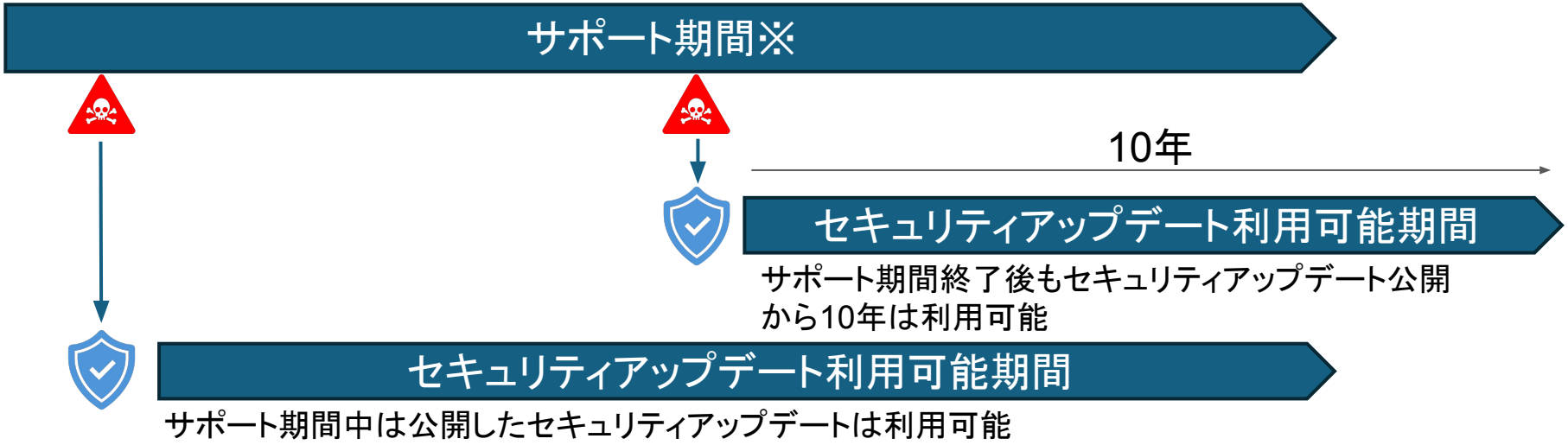
- 脆弱性を特定した場合、脆弱性に対処し、その脆弱性を改善しなければならない (Article13(6))
- 脆弱性に対処するためのソフトウェアまたはハードウェアの修正を開発した場合、適切な場合には、関連するコードまたは文書を機械可読形式で、そのコンポーネントを製造または維持している者または事業体と共有しなければならない (Article13(6))
- 機械可読形式で一般的に使用されるSBOM（少なくとも最上位レベルの依存関係含む）を作成すること (附属書 Ⅰ パートⅡ(1))

3. セキュリティアップデートの提供

- サポート期間は5年間と製品の使用期限のうち短い方とし、期間内はマニュファクチャラーは脆弱性に効果的に対処する (Article13(8))
- セキュリティアップデート公開から10年間、またはサポート期間のいずれか長い方の期間、セキュリティアップデートを利用可能とする (Article13(9))

アップデートの提供

CRA Article13-9
Manufacturers shall ensure that each security update, as referred to in Part II, point (8), of Annex I, which has been made available to users during the support period, remains available after it has been issued for a minimum of 10 years or for the remainder of the support period, whichever is longer.



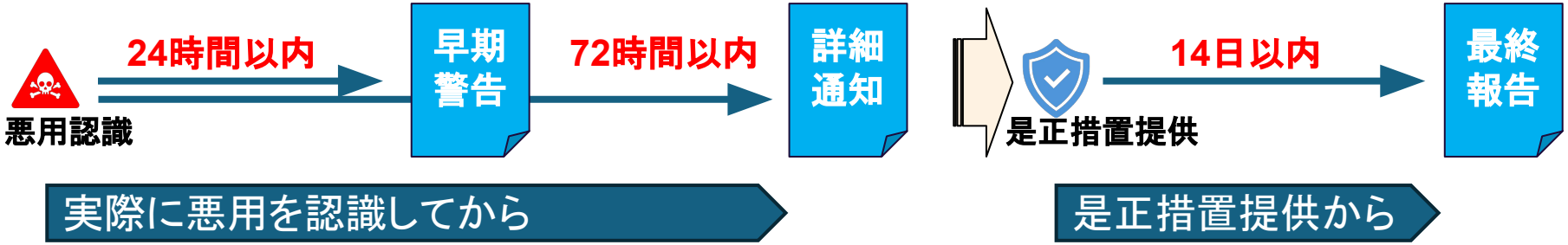
※サポート期間：新たに発見された脆弱性についてセキュリティアップデート提供が必要な期間

4. 報告義務

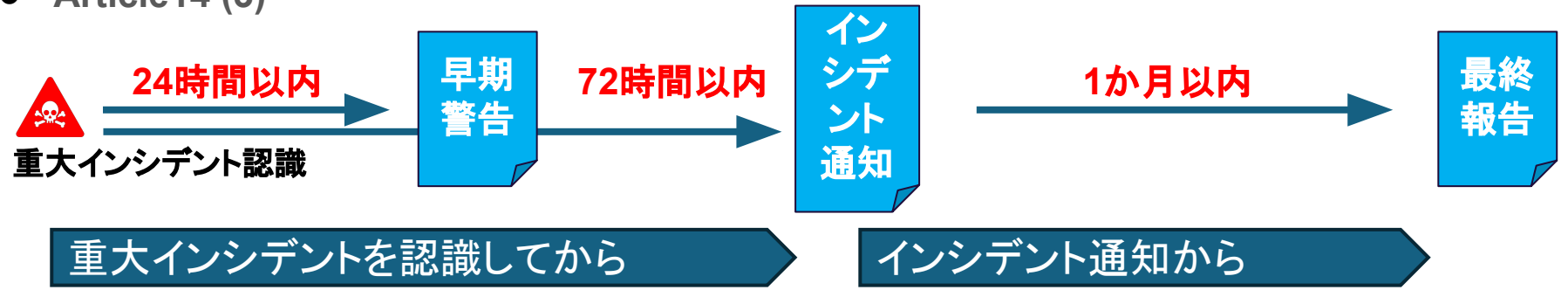
- 悪用されている脆弱性を認識した場合は、認識してから24時間以内に CSIRT と ENISAのSRP (Single Reporting Platform) に同時に早期警告通知、72時間以内に脆弱性通知 (Article14(1),(2))
- 是正・緩和措置提供から14日以内に最終報告 (Article14(1),(2))
- 重大なインシデントを認識した場合は、認識してから24時間以内に CSIRT と ENISAのSRP (Single Reporting Platform) に同時に早期警告通知、72時間以内に是正・緩和措置を含むインシデント通知 (Article14(3),(4))
- インシデント通知から1か月以内に最終報告 (Article14(3),(4))

報告義務のタイムライン

- Article14 (1)



- Article14 (3)



罰則・制約

罰則・制約

- サポート期間内に附属書I「セキュリティ特性要件」を遵守しない場合、直ちに必要な是正措置を講じ製品の撤回またはリコールを□う (Article13(21))
- 附属書Iのサイバーセキュリティ必須要件と第13条および第14条に定める義務に違反した場合、1,500万ユーロ、または違反者が企業の場合は前年会計年度の全世界売上の2.5%のいずれか高い方を上限として罰金を課す (Article64(2))
- 第18条から23条、第28条、第30条の(1)から(4)、第31条の(1)から(4)、第32条の(1)(2)(3)、第33条(5)、第39条、第41条、第47条、第49条、第53条への違反 → 1,000万ユーロ、または全世界売上の 2.0% のうち高い方の罰金 (Article64(3))
- 不正確な情報提示 → 500万ユーロ、または全世界売上の 1.0% のうち高い方の罰金 (Article64(4))

最新動向

Draft Commission guidance on the Cyber Resilience Act

Draft Commission guidance on the Cyber Resilience Act(CRA Guidance (Draft))

- 欧州委員会がCRA第26条の定めに沿ってCRAガイダンス(コミュニケーション法令）発行に向けてドラフトを公開
  Draft Commission guidance on the Cyber Resilience Act

- 欧州委員会の公式ガイダンスであり、企業がCRAをどう解釈・適用すべきかを説明するのが目的。法的拘束力はないが、執行当局の共通解釈の基準になる

- CRA 全体を網羅するものではなく、特定の主要な規定の背景にある考え方や、実務でどのように実施され得るかに関し明確化するもの
  例）CRAの適用範囲、サポート期間の概念、他のEU法との関係、実質的な変更　など

CRA Guidanceの目次 -1

章	項	タイトル
1		イントロダクション (Introduction)
	1.1	サイバーリジリエンス法 (The Cyber Resilience Act)
	1.2	本ガイダンスの目的 (Purpose of the guidance)
2		適用範囲 (Scope)
	2.1	上市 (Placing on the market)
	2.2	HWとSW結合 (Combination of hardware and software forming a product)
	2.3	ソースコード (Source code)
	2.4	データ接続 (Data connection)
	2.5	複雑なシステム (Complex systems)
	2.6	既存製品 (Products designed before the CRA entered into application)

章	項	タイトル
3		フリーオープンソースソフトウェア (FOSS)
	3.1	責任者の判断 (Determining if free and open-source software is under one's responsibility)
	3.2	上市の判断 (Determining if free and open-source software is placed on the EU market)
	3.3	OSSスチュワード (Open-source software stewards)
	3.4	コントリビューターとダウンストリームユース (Contributors and downstream uses)
	3.5	シナリオ例 (Illustrative scenarios)
4		実質的変更 (Substantial modifications and spare parts)
	4.1	物理修正 (Physical repairs)
	4.2	スペアパーツ (Spare parts)
	4.3	実質的変更SW アップデート (Software updates as substantial modifications)

CRA Guidanceの目次 -2

章	項	タイトル
	4.4	大幅変更結果 (Consequences of a substantial modification)
5		サポート期間 (Support period)
6		重要製品と最重要製品 (Important and critical products)
	6.1	コア機能 (Core functionality)
	6.2	適合性評価 (Conformity assessment for important and critical products)
	6.3	適合性の推定に関する影響 (Implications for presumption of conformity)
7		リスクアセスメントとリスクの扱い (Cybersecurity risk assessment and treatment of cybersecurity risk)
	7.1	リスクの評価と扱い (On the evaluation and treatment of cybersecurity risks)
	7.2	リスクベースの製品設計・開発・製造 (On designing, developing and producing products in such a way that they ensure an appropriate level of cybersecurity based on the risks)
	7.3	リスク評価とデューデリジェンス (Risk assessment and due diligence in relation to external dependencies and integrated components)
	7.4	製品ファミリーに対するリスク評価および適合性文書の再利用 (Re-use of risk assessments and conformity documentation for product families)

CRA Guidanceの目次 -3

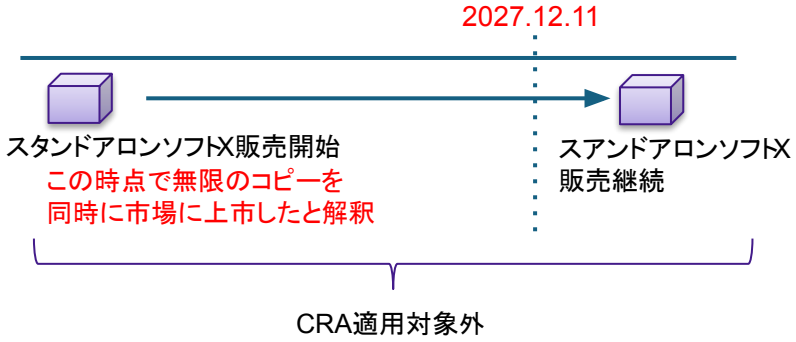
章	項	タイトル
8		リモードデータプロセッシング (Remote data processing)
	8.1	リモートデータ処理ソリューションと見なされる製品　(What is considered a remote data processing solution for a product with digital elements?)
	8.2	リモートデータ処理ソリューションおよびサードパーティソリューションへの依存がもたらす実務的・技術的な影響　(Practical and technical implications of remote data processing solutions and reliance on third-party solutions)
	8.3	リモートデータ処理ソリューションのユースケース　(Use cases for remote data processing solutions)
9		補足 (Additional elements)
	9.1	レポート義務 (On reporting obligations)
	9.2	脆弱性ハンドリング (On vulnerability handling)
	9.3	他の法律との関係 (Interplay with other legislation)

2.1 Placing on the market（スタンドアロンSW特例）

- デジタル手段によって提供されるスタンドアロンのソフトウェア製品に限って、EU 市場で初めて提供された時点で、同一のソフトウェア製品のほぼ無限のコピーを同時に市場に上市したものと解釈される
- デジタル手段による提供とスタンドアロンソフトウェアという2つの条件が揃っている場合に限られる
- したがって、ソフトウェアが物理的手段（USBフラッシュなど）で提供される場合やスタンドアロンソフトウェアではない場合には特例に該当しない。

14. Therefore, a standalone software product should be considered to have been placed on the market when its manufacturing phase is complete and that software is first supplied for distribution or use on the EU market in the course of a commercial activity. The manufacturer should be considered to have placed on the market a virtually infinite number of copies of the same software product at the same time. Therefore, while multiple copies of the same software remain individual products, they are considered to be placed on the market at the same time, regardless of when possession or use of each individual copy is transferred to another natural or legal person.

Example 1: On 1 January 2028, company A first supplies for distribution via its website version 1.0.0 of its software X. On the same day, customer 1 purchases a copy of version 1.0.0 of software X. On 15 January 2028, customer 2 purchases a copy of version 1.0.0 of software X. Both copies of version 1.0.0 of software X are placed on the market on 1 January 2028.



3. FOSS（オープンソースソフトウェア）

- FOSSそのものは非商用提供の場合原則CRA対象外
- 有償提供、メンテナンスなど他サービスでの収益化、など実質的に対価を取っている場合はCRA対象
- 例20：商用OS製品を販売している法人が同社のOS製品向けOSSライブラリを参考実装として無償公開
  ⇒OSSスチュワード

3.2.7 Integration by other manufacturers

64. In some cases, a FOSS is published by a clearly identifiable natural or legal person, but that FOSS is 'intended for integration by other manufacturers into their own products with digital elements'. In such cases, that FOSS is not considered to be placed on the EU market, unless it is also monetised by the person that publishes it (i.e. the original manufacturer), in line with previous sections of this guidance.

65. Where that FOSS is not placed on the market, the legal person publishing it would be subject to the obligations of stewards, if it provides support on a sustained basis, in line with the definition of 'steward'.

Example 19: A legal person publishes a free and open-source JavaScript library for building user interfaces. It does not monetise the supply of that library, but integrates it into another of its products (which is in turn monetised). The JavaScript library is not considered placed on the market within the meaning of the CRA, but the legal person that publishes it is its steward.

Example 20: A legal person places an operating system on the market, and also publishes FOSS libraries to serve as reference implementations for users of that operating system. The legal person does not monetise the FOSS libraries. The legal person that publishes them is a steward to those FOSS libraries.

20

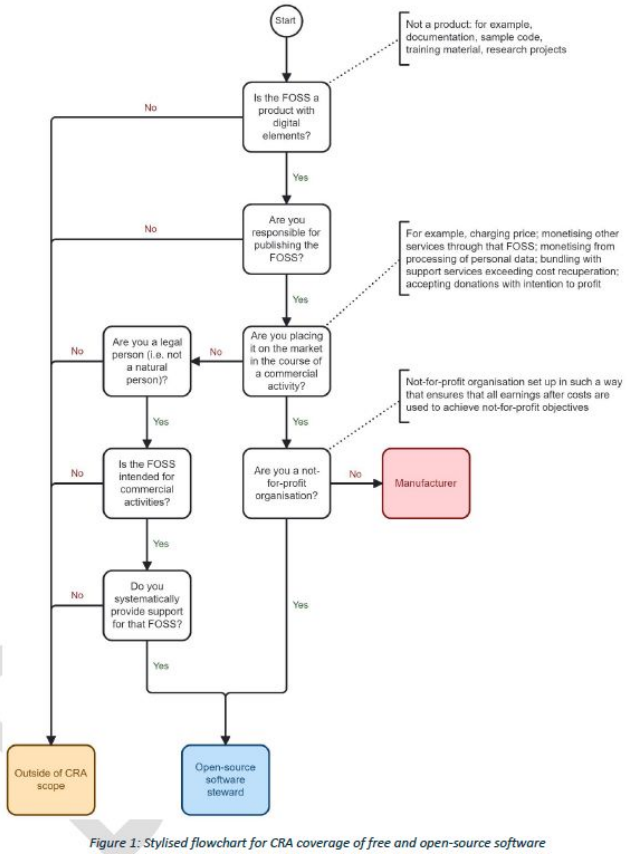


Figure 1: Stylised flowchart for CRA coverage of free and open-source software

9.3 Interplay with other legislation（他の法規制との相互作用）

- 部品がRegulation(EU) 2019/2144車両一般安全規則（General Safety Regulation: GSR）および規則 (EU) No 168/2013が対象とする車両に組み込むために専ら設計・製造されている場合に限り、当該部品はCRA の対象外と考えられる
- たとえ車両向けに設計・製造されていても車両以外に組み込まれる可能性がある場合にはCRA対象となる。例えばオンライン販売など自動車サプライチェーン外の顧客にも開かれた流通チャネルを通じて提供する場合、その部品はCRA の適用範囲に含まれる。

219. It is considered that such components are not subject to the CRA, provided that they are exclusively designed and constructed for integration into vehicles covered by Regulations (EU) 2019/2144 and No 168/2013. This is the case regardless of whether the manufacturer of that component sells it directly to the vehicle manufacturer or to another economic operator in the automotive supply chain, as long as the component is clearly intended and suitable only for ultimate integration within those vehicles.

220. By contrast, a manufacturer that sells generic components that are products with digital elements that can be integrated into different types of product, and not exclusively into vehicles covered by those Regulations, is subject to the CRA.

221. The assessment of whether a component is placed on the market within the meaning of the CRA must be based on the objective conditions under which it is made available. Where a manufacturer offers a component that is not exclusively suitable for ultimate integration within those vehicles through distribution channels that are open to customers outside the automotive supply chain, such as general retail outlets or online sales channels accepting orders from the general public, that component falls within the scope of the CRA, irrespective of any statements concerning its intended use. In such circumstances, the component cannot be considered as being designed and constructed exclusively for integration into vehicles covered by Regulations (EU) 2019/2144 and No 168/2013, and the manufacturer is required to comply with the CRA. By contrast, the use

その他

欧州委員会関連の更新情報

- Single Reporting Platform (SRP) Single Reporting Platform (SRP) | ENISA
  ENISAが脆弱性報告窓口に関してニュースリリース発行。2026年9月11日より運用開始
  Article14(1)および(3)、ならびにArticle15(1)および(2)に規定されている通知のために設置

- Listing of Notified Bodies for CRA Notifying authorities
  欧州委員会による通知機関のリスト。随時更新

- Listing of Market Surveillance Authorities for CRA Market Surveillance Authorities
  欧州委員会による市場監視当局のリスト。随時更新

欧州委員会関連の更新情報

- FAQs on the CRA implementation Cyber Resilience Act implementation – Frequently asked questions
  CRAに対応する際の参考情報としてEuropa Commission expert groupが2025.12.3に発行

- Harmonized Stadards（整合規格）
  欧州委員会はデジタル製品がEU官報に掲載された整合規格に適合している場合、CRAのサイバーセキュリティ要件に適合していると推定する。欧州委員会は整合規格の策定を1つ以上の欧州標準化機関に要請する。（第27条1項）

  2025.4.3 欧州委員会からの要請をCEN/CENELEC、ETSIが正式に受理
  ・2027年12月11日の1年前までに整合規格を準備
  ・Horizontal Standards（製品カテゴリ非依存）とVertical Standards（製品カテゴリ別）の2つのクラスに分けて策定
  ・採択予定
  Horizontal Standards：2026年8月、Vertical Standards：2026年10月 Interview - convenor of CEN-CENELEC Joint TC 13 - Working Groups 6 and 9

Linux Foundation関連の更新情報

- LF 2026_CRA_Awareness_Readiness_Report

  Linux FoundationによるCRA認知度および準備状況レポート

  CRA Awareness Report(英文)　CRA Awareness Report(和文)

- Built to Last (Understanding the European Cyber Resilience Act)

  OpenSSF Global Cyber Policy WGによるCRAガイド

  Built to Last(英文)　Built to Last(和文)　coming soon

LF Trainingの紹介

EU CRAに関するLF Trainingコースの提供が開始されました（無料）

Understanding the EU Cyber Resilience Act(CRA)(LFEL1001)

最後に。。。

CRAをポジティブに捉えましょう！

Open Source Security に取り組んでいる我々だからこそ、CRAをネガティブに捉えずに
CRAを追い風にしてセキュリティの重要性を広く普及させるきっかけにしましょう！

Thank you



Legal Notice

Copyright © Open Source Security Foundation®, The Linux Foundation®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners.

Per the OpenSSF Charter, this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <https://creativecommons.org/licenses/by/4.0/>. You are free to:

- Share — copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt — remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution — You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.

Appendix



47

CRA の全体的な構成

CRA 全体目次-1

CHAPTER I GENERAL PROVISIONS
Article 1 Subject matter
Article 2 Scope
Article 3 Definitions
Article 4 Free movement
Article 5 Procurement or use of products with digital elements
Article 6 Requirements for products with digital elements
Article 7 Important products with digital elements
Article 8 Critical products with digital elements
Article 9 Stakeholder consultation
Article 10 Enhancing skills in a cyber resilient digital environment
Article 11 General product safety
Article 12 High-risk AI systems

CHAPTER II OBLIGATIONS OF ECONOMIC OPERATORS AND PROVISIONS IN RELATION TO FREE AND OPEN-SOURCE SOFTWARE
Article 13 Obligations of manufacturers
Article 14 Reporting obligations of manufacturers
Article 15 Voluntary reporting
Article 16 Establishment of a single reporting platform
Article 17 Other provisions related to reporting
Article 18 Authorised representatives
Article 19 Obligations of importers
Article 20 Obligations of distributors
Article 21 Cases in which obligations of manufacturers apply to importers and distributors
Article 22 Other cases in which obligations of manufacturers apply
Article 23 Identification of economic operators
Article 24 Obligations of open-source software stewards
Article 25 Security attestation of free and open-source software
Article 26 Guidance

※EU官報のCRA公示へのリンク

CRA 全体目次-2

CHAPTER III Conformity of the product with digital elements
Article 27 Presumption of conformity
Article 28 EU declaration of conformity
Article 29 General principles of the CE marking
Article 30 Rules and conditions for affixing the CE marking
Article 31 Technical documentation
Article 32 Conformity assessment procedures for products with digital elements
Article 33 Support measures for microenterprises and small and medium-sized enterprises, including start-ups
Article 34 Mutual recognition agreements

CHAPTER IV NOTIFICATION OF CONFORMITY ASSESSMENT BODIES
Article 35 Notification
Article 36 Notifying authorities
Article 37 Requirements relating to notifying authorities
Article 38 Information obligation on notifying authorities
Article 39 Requirements relating to notified bodies
Article 40 Presumption of conformity of notified bodies
Article 41 Subsidiaries of and subcontracting by notified bodies
Article 42 Application for notification
Article 43 Notification procedure
Article 44 Identification numbers and lists of notified bodies
Article 45 Changes to notifications
Article 46 Challenge of the competence of notified bodies.
Article 47 Operational obligations of notified bodies
Article 48 Appeal against decisions of notified bodies
Article 49 Information obligation on notified bodies
Article 50 Exchange of experience
Article 51 Coordination of notified bodies

CRA 全体目次-3

CHAPTER V MARKET SURVEILLANCE AND ENFORCEMENT
Article 52 Market surveillance and control of products with digital elements in the Union market
Article 53 Access to data and documentation
Article 54 Procedure at national level concerning products with digital elements presenting a significant cybersecurity risk
Article 55 Union safeguard procedure
Article 56 Procedure at Union level concerning products with digital elements presenting a significant cybersecurity risk
Article 57 Compliant products with digital elements which present a significant cybersecurity risk
Article 58 Formal non-compliance
Article 59 Joint activities of market surveillance authorities
Article 60 Sweeps

CHAPTER VI DELEGATED POWERS AND COMMITTEE PROCEDURE
Article 61 Exercise of the delegation
Article 62 Committee procedure

CHAPTER VII CONFIDENTIALITY AND PENALTIES
Article 63 Confidentiality
Article 64 Penalties
Article 65 Representative actions

CHAPTER VIII TRANSITIONAL AND FINAL PROVISIONS
Article 66 Amendment to Regulation (EU) 2019/1020
Article 67 Amendment to Directive (EU) 2020/1828
Article 68 Amendment to Regulation (EU) No 168/2013
Article 69 Transitional provisions
Article 70 Evaluation and review
Article 71 Entry into force and application

CRA Annex

ANNEX I
ESSENTIAL CYBERSECURITY REQUIREMENTS
Part I Cybersecurity requirements relating to the properties of products with digital elements
Part II Vulnerability handling requirements
ANNEX II
INFORMATION AND INSTRUCTIONS TO THE USER
ANNEX III
IMPORTANT PRODUCTS WITH DIGITAL ELEMENTS
Class I
Class II
ANNEX IV
CRITICAL PRODUCTS WITH DIGITAL ELEMENTS
ANNEX V
EU DECLARATION OF CONFORMITY
ANNEX VI
SIMPLIFIED EU DECLARATION OF CONFORMITY
ANNEX VII
CONTENT OF THE TECHNICAL DOCUMENTATION
ANNEX VIII
CONFORMITY ASSESSMENT PROCEDURES
Part I Conformity assessment procedure based on internal control (based on module A)
Part II EU-type examination (based on module B)
Part III Conformity to type based on internal production control (based on module C)
Part IV Conformity based on full quality assurance (based on module H)

CRA で求められる要件

CRA 第13条 マニュファクチャラーの義務

1. デジタル製品を市場に出す際、附属書Iの1「セキュリティ特性要件」を遵守して設計・開発・製造 されていることを確認する。
2. サイバーセキュリティ上の**リスクアセスメントを実施** し、その結果を設計・開発・製造・配送・メンテナ ンスの際の考慮に□れる。
3. デジタル製品を市場に出す際、上記の**リスクアセスメントの結果を技術 □書に含める**。
4. 第31条および付属書VIIに従って要求される技術文書には、本条第3項で言及されるサイバーセキュリティリスク評価を含める。
5. 第三者から提供された部品を使□する際は、その部品により製品のセキュリティリスクを□めないことを保証する。
6. 特定した脆弱性を報告・対処・修復する。対処のための変更は機械可読形式でコンポーネントの製造または保守を行う個人または団体と共有する。
7. デジタル製品に関する**サイバーセキュリティ観点の情報を体系的に □書化**する。
8. **サポート期間は 5年間と製品の使用期限のうち短い方とし、期間内はマニュファクチャラーは脆弱性に効果的に対処する** 。マニュファクチャラーは脆弱性開等に適切なポリシーや□続きを有する。
9. **セキュリティアップデート公開から 10年間、またはサポート期間のいずれか長い方の期間、セキュリティアップデートを利用可能とする** 。
10. 大幅な変更バージョンは付属書 I、パート II、ポイント (2) の必須要件に準拠すればよい。最新バージョンへは無料でアクセスでき、旧バージョンユーザーが環境調整コストなしで適用できること。
11. ユーザーが過去のバージョンおよびサポート外ソフトウェアの使用に伴うリスク情報にアクセスできるようにする。
12. 上市前にマニュファクチャラーは技術□書を作成する。対応する適合性評価□続きを□い、適合性が実証された場合はCEマーキングを貼付する。
13. 上市後10年間、技術□書と(該当する場合は)EU適合性証明書を市場監視当局が□由に使えるように保管する。
14. □連の製造の中で、適合性を維持するための□順が整備されていることを確認する。
15. 製品の個体識別のため型番、バッチ番号、シリアル番号などを付記する。
16. 製品にマニュファクチャラーの名前、商標、郵便住所、電子メールアドレスなどのデジタル連絡先、ウェブサイトなどを表示する。
17. 脆弱性報告ための単一の連絡先を附属書 II に記載されているユーザーへの情報および指示に記載する。連絡先はユーザーが通信手段を選択できるようにし、手段を自動化ツールに限定してはならない。
18. 附属書 II に定めるユーザーへの情報および説明書を**紙または電子形式で添付** する。情報および説明書は10年間とサポート期間の長い方の期間保持し、オンライン提供の場合はアクセス可能とする。
19. 購入時に、第8項のサポート期間の終了日へアクセスできるようにする。可能であれば、マニュファクチャラーはサポート期間の終了をユーザーに通知する。
20. **EU適合性証明書か簡易 EU適合宣言を提供する** 。簡易宣言の場合は完全なEU適合宣言へのURLを提供する。
21. **サポート期間内に附属書 III「セキュリティ特性要件」を遵守しない場合、直ちに必要な是正措置を講じ製品の撤回またはリコールを □う**。
22. 市場監視当局からの要求に応じて製品の適合性を証明する情報・□書を提出する。
23. 操業を停□し義務を遵守できなくなる場合、操業停□前に市場監視当局やユーザに通知する。
24. 欧州委員会は実施法の中で、SBOMの形式と要素を指定することができる。
25. ADCO は製品のフリーソフトウェアおよびオープンソースソフトウェアへの依存度評価の実施を決定できる。市場監視当局は附属書I第II部ポイント(1)の SBOM 提供を要求できる。

設計前のリスクアセスメントの実施及び設計書への反映を文書化する必要がある。
製品寿命もしくは5年間は脆弱性処理要件を満たす必要がある。(PSIRT相当の対応が必須)

CRA 第14条 マニュファクチャラーの報告義務

1. **実際に悪用されている脆弱性を認識した場合は**　第7項に従い **CSIRT と ENISA に同時に通知** する。
2. 第1項の通知では以下を提出する。
   (a) 脆弱性を認識してから **24時間以内に早期警告通知**
   (b) 脆弱性を認識してから **72時間以内に**、製品の一般情報、悪用の性質、講じられた・またはユーザーが講じられる是正・緩和措置を含む **脆弱性通知**
   (c) 是正措置または緩和措置が利用可能になってから **14日以内に以下を含む最終報告書**
      (i) 脆弱性の説明（その深刻度および影響を含む）
      (ii) 入手可能な場合、脆弱性を悪用した悪意のある行為者に関する情報
      (iii) 脆弱性修正のためのセキュリティアップデートまたはその他の是正措置に関する詳細
3. 製品のセキュリティに影響を与える **重大なインシデントを認識した場合は**　第7項に従い **CSIRT と ENISA に同時に通知** する
4. 第3項の通知では以下を提出する。
   (a) インシデントを認識してから **24時間以内に早期警告通知**。違法または悪意のある行為により比企侵された疑いがあるかを含む
   (b) インシデントを認識してから **72時間以内に**、インシデントに関する一般情報と初期評価、講じられた・またはユーザーが講じられる **是正・緩和措置を含むインシデント通知**
5. 以下の場合インシデントは重大とみなす。
   (a) 機密性の高いまたは重要なデータや機能の可用性、真正性、完全性、または機密性を保護する能力に悪影響を及ぼす可能性がある
   (b) ユーザーのネットワークおよび情報システムにおいて悪意のあるコードの導入または実行につながる可能性がある
6. CSIRT は現在悪用されている脆弱性や重大なインシデントに関する中間レポートの提供を製造元に要求する場合がある。
7. 第1項と第3項の通知は、第 16条で規定する単一の報告プラットフォームを介して提出される。
8. 実際にに悪用されている脆弱性または重大なインシデントを認識した場合、これらについてユーザーに通知する。
9. 本法案発効日から 12ヶ月以内に欧州委員会は第 61条に委任行為を採択する。
10. 欧州委員会は、通知された情報の種類、形式、□順を更に指定することができる。

自社製品に対するサイバーセキュリティ・インシデントへの報告・対応・連絡を行う組織が求められる
当該義務は法律施行前に販売を開始し、施行後も出荷を継続する製品にも課せられることに注意　(第69条 経過規程 3)

CRAで求められる要件

附属書 I の Part I「セキュリティ特性要件」

1. リスクに基づいて適切なサイバーセキュリティを確保するよう設計・開発・生産されていること。
2. リスクベースアセスメントに基づいて、以下を満たすこと。
   - (a) 悪用可能な脆弱性が含まれないこと。
   - (b) 製品を元の状態にリセット可能である等、デフォルトで安全な設定となっていること。
   - (c) セキュリティアップデートにより脆弱性に対処できること。
   - (d) 適切な制御メカニズムにより不正アクセスからの保護が確保されていること。
   - (e) 最先端の暗号化などにより個人データ・その他のデータの機密性を保護すること。
   - (f) データやプログラムなどの完全性を許可されていない操作から保護し、破損についても報告すること。
   - (g) 必要なデータに限定して処理を行うこと。（データの最小化）
   - (h) DoS攻撃からの回復・緩和などの重要な可用性の機能を保護すること。
   - (i) 他の機器やネットワークからのサービスの可用性について自身への悪影響を最小化すること。
   - (j) 外部インターフェース等の攻撃対象領域を制限して設計・開発・製造されていること。
   - (k) インシデントの影響を軽減するように設計・開発・製造されているころ。
   - (l) アクセス、データ修正、サービス、機能などの内部活動を記録・監視し、セキュリティ情報を提供すること。
   - (m) ユーザーが全てのデータと設定を簡単に永久に削除できること。それら情報が転送可能な場合は安全に転送できること。

附属書Iの Part II「脆弱性処理要件」・・・マニュファクチャラーが満たすべき要件

1. 製品に含まれる脆弱性とコンポーネントを特定し、文書化すること。
   - 機械可読形式で 一般的に使用される SBOM作成（少なくとも最上位レベルの依存関係含む）を行う こと。
2. セキュリティアップデートの提供など、遅滞なく脆弱性に対処・緩和すること。
3. 効果的かつ定期的なテストとレビューを行うこと。
4. 修正された脆弱性について、情報の公開を行うこと。
5. 脆弱性開示ポリシーを導入し、実施すること。
6. 製品やサードパーティコンポーネントの潜在的な脆弱性に関する情報共有 を行い、連絡先を提供すること。
7. 悪用可能な脆弱性が適時に修正・緩和されるように安全にアップデートを配布するメカニズムを提供すること。
8. セキュリティパッチや更新プログラムが遅滞なく無料で配布され、ユーザーへの助言メッセージも添付すること。